

Тема 6. Впровадження CIS Controls

План впровадження контролів безпеки CIS Controls для організації

Організація: ТОВ «FinSecure Ukraine» (фінтех-компанія, онлайн-кредитування та платіжні сервіси)

Кількість співробітників: ~150 | IT-інфраструктура: гібридна (хмара + локальні сервери)

Дата: 09.07.2026

1. Опис організації та контекст

ТОВ «FinSecure Ukraine» — фінтех-компанія, що надає послуги онлайн-кредитування та обробки платежів фізичним і юридичним особам. Компанія обробляє персональні дані клієнтів (ПІБ, ПІН, банківські реквізити), фінансову інформацію та інтегрована з платіжними системами і кредитними бюро через API. Інфраструктура є гібридною: частина сервісів розміщена в хмарі (AWS), частина — на локальних серверах у центральному офісі.

Через характер діяльності компанія є привабливою мішенню для кіберзлочинців (шахрайство з платежами, викрадення персональних даних, атаки на API), а також підпадає під вимоги регуляторів (НБУ, Закон України «Про захист персональних даних», рекомендації PCI DSS). Це визначає пріоритетність контролів, пов'язаних із захистом даних, керуванням доступом та моніторингом мережі.

1.1. Основні ризики організації

- Несанкціонований доступ до особистих кабінетів клієнтів та внутрішніх систем.
- Витік або втрата персональних і фінансових даних клієнтів.
- Компрометація облікових записів співробітників з підвищеними привілеями (адміністратори, фінансові аналітики).
- Атаки на мережеву інфраструктуру (DDoS, перехоплення трафіку, несанкціоноване проникнення).
- Відсутність своєчасного виявлення та реагування на інциденти безпеки.

2. Обрані CIS Controls та обґрунтування вибору

З огляду на профіль ризиків та специфіку діяльності компанії обрано п'ять контролів CIS Controls (v8), що охоплюють видимість активів, керування доступом, захист даних, мережеву безпеку та реагування на інциденти — тобто повний цикл «знати → захистити → виявити → відреагувати».

2.1. CIS Control 1 — Інвентаризація та контроль корпоративних активів

Обґрунтування: неможливо захистити те, про що невідомо. У компанії наявні хмарні та локальні сервери, робочі станції, мобільні пристрої співробітників і API-інтеграції з партнерами. Без актуального реєстру активів неможливо коректно застосувати інші контролі (патчі, доступ, моніторинг), а «тіньові» пристрої чи сервіси стають найпростішою точкою входу для зловмисника.

2.2. CIS Control 4 — Контроль доступу та керування привілеями

Обґрунтування: адміністратори баз даних, фінансові аналітики та підрядники мають розширені права доступу до систем із чутливими даними. Надлишкові або неконтрольовані привілеї — одна з найчастіших причин витоків даних у фінансовому секторі. Контроль забезпечує принцип найменших привілеїв (least privilege) та регулярний перегляд прав доступу.

2.3. CIS Control 5 — Захист даних

Обґрунтування: персональні та фінансові дані клієнтів є найціннішим активом компанії та об'єктом регуляторних вимог (Закон України «Про захист персональних даних», PCI DSS). Контроль охоплює класифікацію даних, шифрування в стані спокою та під час передачі, а також процедури безпечного видалення.

2.4. CIS Control 9 — Захист мережі

Обґрунтування: гібридна інфраструктура (хмара + локальні сервери) та інтеграції з зовнішніми API створюють численні точки мережевого периметра. Належна сегментація мережі, захист від DDoS, шифрування трафіку (TLS) та контроль вихідних/вхідних з'єднань суттєво знижують ризик компрометації.

2.5. CIS Control 17 — Управління реагуванням на інциденти

Обґрунтування: навіть за наявності превентивних заходів жодна організація не застрахована від інцидентів. Формалізований план реагування дозволяє мінімізувати збитки, дотриматися вимог щодо повідомлення регулятора про витік даних (72 години за аналогією з GDPR-практикою) та зберегти довіру клієнтів.

3. Детальний план впровадження

Для кожного обраного контролю нижче наведено: важливість для організації, кроки реалізації, відповідальних осіб, необхідні ресурси та терміни виконання.

3.1. CIS Control 1 — Інвентаризація та контроль корпоративних активів

Параметр	Опис
Важливість	Формує основу для всіх інших контролів безпеки: неможливо захистити, пропатчити чи моніторити актив, який не занесено до реєстру. Знижує ризик «тіньових ІТ» та застарілого обладнання/ПЗ.
Кроки реалізації	1) Провести повну інвентаризацію апаратних та програмних активів (сервери, робочі станції, мобільні пристрої, хмарні ресурси AWS). 2) Впровадити автоматизований інструмент обліку активів (напр. Lansweeper або AWS Config для хмари). 3) Класифікувати активи за критичністю (критичні, важливі, другорядні). 4) Налаштувати автоматичне виявлення нових/несанкціонованих пристроїв у мережі. 5) Впровадити регламент щоквартального оновлення реєстру.
Відповідальні особи	ІТ-адміністратор (веде реєстр), керівник відділу інфраструктури (затверджує класифікацію), служба безпеки (аудит відповідності).
Оцінка ресурсів	Ліцензія на систему обліку активів (~\$2 000–3 000/рік), 40 людино-годин на первинну інвентаризацію, навчання персоналу роботі з інструментом (1 день тренінгу).
Терміни виконання	Місяць 1: первинна інвентаризація. Місяць 2: впровадження автоматизованого інструменту та регламенту оновлення.

3.2. CIS Control 4 — Контроль доступу та керування привілеями

Параметр	Опис
Важливість	Обмежує потенційну шкоду від компрометованого облікового запису та внутрішніх зловживань. Критично для систем, що обробляють платежі та фінансові операції.
Кроки реалізації	1) Провести аудит існуючих облікових записів та привілеїв. 2) Впровадити принцип найменших привілеїв (least privilege) для всіх ролей. 3) Налаштувати рольову модель доступу (RBAC) для систем кредитування та платежів. 4) Впровадити багатофакторну автентифікацію (MFA) для всіх привілейованих облікових записів. 5) Встановити процедуру щоквартального перегляду прав доступу та негайного відкликання доступу при звільненні співробітника.
Відповідальні особи	Адміністратор систем безпеки (налаштування RBAC/MFA), HR-відділ (інформування про звільнення/переведення), керівники підрозділів (погодження рівня доступу підлеглих).
Оцінка ресурсів	Рішення для MFA (~\$3–5 на користувача/місяць), інструмент керування ідентичністю (IAM), 60 людино-годин на аудит і впровадження RBAC, навчання адміністраторів.

Параметр	Опис
Терміни виконання	Місяць 1: аудит облікових записів. Місяць 2: впровадження MFA для привілейованих акаунтів. Місяць 3: повне впровадження RBAC та регламенту перегляду доступу.

3.3. CIS Control 5 — Захист даних

Параметр	Опис
Важливість	Персональні та фінансові дані клієнтів — головний актив і головна регуляторна відповідальність компанії. Витік таких даних веде до фінансових втрат, штрафів та репутаційних ризиків.
Кроки реалізації	1) Класифікувати дані за рівнем чутливості (публічні, внутрішні, конфіденційні, персональні/фінансові). 2) Впровадити шифрування даних у стані спокою (AES-256 для баз даних) та під час передачі (TLS 1.2+/1.3 для всіх з'єднань, включно з API). 3) Налаштувати систему запобігання витокам даних (DLP) для каналів електронної пошти та файлових сховищ. 4) Впровадити регулярне резервне копіювання з шифруванням та тестуванням відновлення. 5) Розробити політику безпечного знищення даних після завершення терміну зберігання.
Відповідальні особи	Спеціаліст із захисту даних / DPO (політика та відповідність вимогам законодавства), адміністратор баз даних (шифрування, резервне копіювання), служба безпеки (впровадження DLP).
Оцінка ресурсів	Рішення DLP (~\$8 000–12 000/рік), сертифікати TLS, додаткове сховище для зашифрованих резервних копій, навчання персоналу з роботи з чутливими даними (щорічний тренінг).
Терміни виконання	Місяць 2: класифікація даних та впровадження шифрування. Місяць 3: налаштування DLP. Місяць 4: тестування процедур резервного копіювання та відновлення.

3.4. CIS Control 9 — Захист мережі

Параметр	Опис
Важливість	Мережа — периметр, через який відбувається переважна більшість зовнішніх атак. Належний захист знижує ризик проникнення, перехоплення трафіку та DDoS-атак, що особливо критично для доступності платіжних сервісів.
Кроки реалізації	1) Провести сегментацію мережі: виокремити сегменти для платіжних систем, офісної мережі та гостьового Wi-Fi. 2) Впровадити або оновити конфігурацію міжмережевих екранів (firewall) та систему запобігання вторгненням (IDS/IPS). 3) Забезпечити захист від DDoS-атак на рівні хмарного провайдера (AWS Shield) та мережевого периметра. 4) Налаштувати обов'язкове шифрування трафіку (VPN для віддаленого доступу, TLS для API-інтеграцій). 5) Провести тестування на проникнення (penetration testing) мережевої інфраструктури.
Відповідальні особи	Мережевий інженер (сегментація, firewall/IDS-IPS), хмарний архітектор (AWS Shield, конфігурація хмарної мережі), зовнішній підрядник (пентест).
Оцінка ресурсів	AWS Shield Advanced (~\$3 000/місяць), оновлення обладнання firewall (~\$10 000 одноразово), послуги пентесту (~\$5 000–8 000 за проєкт), 80 людино-годин на сегментацію мережі.
Терміни виконання	Місяць 3: сегментація мережі та оновлення firewall/IDS-IPS. Місяць 4: впровадження захисту від DDoS. Місяць 5: проведення пентесту та усунення

Параметр	Опис
	виявлених вразливостей.

3.5. CIS Control 17 — Управління реагуванням на інциденти

Параметр	Опис
Важливість	Забезпечує швидке та скоординоване реагування на інциденти безпеки, мінімізує фінансові та репутаційні збитки, а також дозволяє дотримуватись вимог щодо своєчасного повідомлення регулятора та клієнтів про витік даних.
Кроки реалізації	1) Розробити формалізований план реагування на інциденти (Incident Response Plan) з визначенням ролей команди реагування (CSIRT). 2) Визначити класифікацію інцидентів за рівнем критичності та відповідні терміни реагування. 3) Впровадити систему централізованого збору та аналізу логів (SIEM) для швидкого виявлення інцидентів. 4) Провести навчальні кіберучення (tabletop exercises) для команди реагування та керівництва. 5) Встановити процедуру пост-інцидентного аналізу (lessons learned) та оновлення плану за результатами.
Відповідальні особи	Керівник служби безпеки (CISO) — координація плану, команда CSIRT (IT, безпека, юридичний відділ, PR), керівництво компанії (затвердження плану, комунікація з регулятором).
Оцінка ресурсів	SIEM-рішення (~\$15 000–20 000/рік залежно від обсягу логів), навчання команди CSIRT (2 тренінги на рік), залучення юридичного консультанта для узгодження процедур повідомлення регулятора.
Терміни виконання	Місяць 4: розробка плану реагування та визначення ролей CSIRT. Місяць 5: впровадження SIEM. Місяць 6: проведення перших кіберучень та фіналізація процедур.

4. Зведений графік впровадження

Нижче наведено узагальнений графік із пріоритетністю та термінами реалізації кожного контролю, що дозволяє керівництву відстежувати прогрес та розподіляти ресурси поетапно, без одночасного навантаження на всі підрозділи.

Контроль CIS	Пріоритет	Термін впровадження
CIS Control 1 — Інвентаризація активів	Високий	Місяць 1–2
CIS Control 4 — Контроль доступу та привілеї	Критичний	Місяць 1–3
CIS Control 5 — Захист даних	Критичний	Місяць 2–4
CIS Control 9 — Захист мережі	Високий	Місяць 3–5
CIS Control 17 — Реагування на інциденти	Середній	Місяць 4–6

5. Узгодження плану з бізнес-цілями організації

План побудовано так, щоб посилення кібербезпеки не створювало надмірного навантаження на бізнес-процеси компанії й водночас відповідало її фінансовим можливостям.

5.1. Реалістичність та відповідність ресурсам

- Впровадження розбито на 6 місяців поетапно — кожен контроль вводиться послідовно, що дозволяє уникнути одночасного навантаження на IT-бюджет і персонал.
- Обрано рішення з масштабованою вартістю (хмарні сервіси AWS, SaaS-рішення для MFA/DLP), що відповідають розміру компанії (~150 співробітників) без надлишкових корпоративних ліцензій.
- Загальний орієнтовний бюджет на перший рік впровадження — в межах типового IT-бюджету компанії такого розміру (орієнтовно \$60 000–80 000 сукупно на всі контролю, включно з ліцензіями, навчанням та послугами підрядників).

5.2. Відповідність бізнес-процесам

- MFA та RBAC впроваджуються з урахуванням зручності клієнтського сервісу — доступ співробітників до систем кредитування прискорюється за рахунок єдиного входу (SSO), а не ускладнюється.
- Сегментація мережі та DDoS-захист напряду підтримують безперервність платіжних сервісів — ключову бізнес-функцію компанії, а не лише вимогу безпеки.
- Політики захисту даних узгоджені з вимогами регулятора (НБУ, законодавство про персональні дані), що знижує ризик штрафів і одночасно підвищує довіру клієнтів та партнерів (банків, кредитних бюро).
- План реагування на інциденти включає юридичний та PR-аспекти, щоб у разі інциденту компанія могла оперативно комунікувати з клієнтами та регулятором, зберігаючи репутацію.

6. Висновок

Впровадження обраних п'яти контролів CIS Controls (Інвентаризація активів, Контроль доступу, Захист даних, Захист мережі, Реагування на інциденти) забезпечить ТОВ «FinSecure Ukraine» комплексний захист критичних активів на всіх етапах життєвого циклу безпеки — від видимості активів до готовності реагувати на інциденти. Поетапний, реалістичний графік впровадження дозволяє досягти суттєвого підвищення рівня кібербезпеки без порушення бізнес-процесів компанії та в межах доступних ресурсів.